

Corporación Universitaria Minuto de Dios

Reporte de Solución de Problemas Matemáticos

Evaluación de la Calidad del Software mediante Métricas, Verificación y Auditoría

Presentado por:

Brayan Rafael Ortega Plata

Asignatura: NRC-93980-Estándares y Métricas de Calidad en el Desarrollo de Software

Semana: 2

Docente: CESAR ALFONSO BOLADO SILVA

Programa: Especialización en Desarrollo de Software

Fecha de entrega: 11/07/2026

Reporte de Solución de Problemas Matemáticos

1. Introducción

La calidad del software es un aspecto fundamental en la creación de herramientas que apoyan la automatización de procesos en los diferentes campos empresariales. Pressman y Maxim (2019) señalan que la calidad del software corresponde al nivel de cumplimiento de los requisitos funcionales y de rendimiento establecidos antes del inicio del proyecto, así como de las características implícitas que se esperan de todo software desarrollado de manera profesional. De esta manera, la calidad orienta el cumplimiento de los requerimientos y necesidades del cliente, permitiendo establecer de forma anticipada si un producto satisface o no la necesidad planteada.

Adicionalmente, la Organización Internacional de Normalización (ISO, 2011), a través de la norma ISO/IEC 25010, propone un modelo de calidad de producto de software estructurado en características como funcionalidad, fiabilidad, usabilidad, eficiencia, mantenibilidad, portabilidad y seguridad, las cuales permiten aplicar objetividad en la evaluación con base en métricas específicas.

En este contexto, la presente actividad desarrolla el análisis de un proyecto hipotético, en el cual se evalúa la calidad de un software antes de su liberación a producción, asumiendo el rol de especialista en aseguramiento de la calidad. Para ello, se analizará el escenario planteado incluyendo requisitos, bitácora de incidencias, control de cambios y resultados de pruebas preliminares mediante actividades de verificación, validación, revisión técnica, auditoría y definición de métricas, con el fin de identificar hallazgos relevantes y formular recomendaciones que soporten la decisión de liberación del sistema.

2. Descripción del escenario evaluado

2.1 Descripción general del sistema

CoopFinanza App es una aplicación móvil (Android/iOS) desarrollada para la Cooperativa Financiera CoopFinanza, que permite a sus asociados realizar consultas de saldo, transferencias interbancarias, pago de servicios públicos, solicitud de créditos exprés y gestión de certificados de aportes. El sistema se conecta a un core bancario legado mediante servicios web (SOAP/REST) y a una pasarela de pagos externa para transacciones interbancarias (ACH).

El proyecto lleva 8 meses de desarrollo, se encuentra en fase de pre-liberación y está programado para salir a producción en 3 semanas, coincidiendo con una campaña comercial de vinculación de nuevos asociados.

2.2 Contexto organizacional

- La Gerencia de Tecnología presiona por cumplir la fecha de lanzamiento debido a compromisos comerciales ya anunciados.
- El equipo de desarrollo está compuesto por 6 desarrolladores (3 con menos de 6 meses en la empresa), 1 líder técnico, 2 analistas QA y 1 arquitecto de soluciones (contratista externo, medio tiempo).
- No existe un área formal de seguridad de la información; las revisiones de seguridad las hace el mismo equipo de desarrollo.
- La cooperativa está regulada por la Superintendencia Financiera y debe cumplir normas de protección de datos personales y estándares de seguridad para medios de pago (tipo PCI-DSS).

2.3 Actores involucrados

- Patrocinador del proyecto: Gerente de Tecnología.
- Product Owner: Jefe de Canales Digitales.
- Equipo de desarrollo: Líder técnico, 6 desarrolladores, arquitecto (contratista).
- Equipo de QA: 2 analistas de pruebas.
- Usuario final: Asociados de la cooperativa (perfil heterogéneo, muchos con bajo nivel de alfabetización digital).
- Ente regulador externo: Superintendencia Financiera.
- Proveedor externo: Pasarela de pagos ACH (integración vía API).

2.4 Funcionalidades críticas

1. Autenticación de usuarios (login con usuario/contraseña + segundo factor OTP por SMS).
2. Transferencias interbancarias en tiempo real.
3. Pago de servicios públicos.
4. Solicitud de créditos exprés (con validación automática de score crediticio).
5. Recuperación/cambio de contraseña.
6. Notificaciones push de movimientos.

2.5. Restricciones técnicas y regulatorias

- El sistema debe cumplir con cifrado de datos sensibles en tránsito y en reposo.
- Los tiempos de respuesta de transacciones no deben superar 5 segundos bajo carga normal.
- Debe existir trazabilidad (logs de auditoría) de todas las operaciones financieras por un mínimo de 5 años.
- La app debe soportar al menos 3,000 usuarios concurrentes en horas pico.
- Debe cumplir con la normativa local de protección de datos personales (habeas data).
- El proveedor de la pasarela ACH exige que las credenciales de integración se manejen mediante variables de entorno cifradas, no hardcodeadas.

2.6 Evidencias disponibles

a) Fragmentos de requisitos (extracto del documento de requisitos):

- RF-012: "El sistema debe permitir el cambio de contraseña enviando un código de verificación al correo o celular registrado."
- RF-018: "El sistema debe bloquear la cuenta después de 5 intentos fallidos de inicio de sesión."
- RF-025: "El sistema debe registrar en bitácora toda transacción mayor a \$500,000."
- RF-031: "El módulo de créditos exprés debe responder en menos de 10 segundos."
- RNF-004: "Las contraseñas deben almacenarse cifradas usando un algoritmo estándar de la industria."

b) Extractos de bitácora de incidencias (últimas 3 semanas de pruebas):

- INC-101 (Alta): Se detectó que las contraseñas se almacenan en la base de datos usando MD5 sin sal.
- INC-104 (Alta): Un analista de QA logró interceptar el token OTP mediante un proxy, ya que viaja en texto plano en un log de depuración que quedó activo en el build de release.
- INC-108 (Media): El bloqueo de cuenta tras 5 intentos fallidos no se activa; se probaron 10 intentos consecutivos sin bloqueo.
- INC-112 (Media): En pruebas de carga con 1,500 usuarios concurrentes, el tiempo de respuesta de transferencias subió a 9 segundos (supera el límite de 5 seg).
- INC-115 (Baja): Las notificaciones push llegan duplicadas en aproximadamente el 8% de los casos.
- INC-119 (Alta): Las credenciales de integración con la pasarela ACH se encontraron hardcodeadas en el código fuente de la app (visibles al descompilar el APK).
- INC-121 (Media): No hay registro en bitácora de auditoría para transacciones realizadas desde el módulo de créditos exprés, contraviniendo RF-025.

c) Lista de control de cambios (Change Log — últimas 4 semanas):

ID	Fecha	Descripción del cambio	Aprobado por	Estado
CR-045	Semana 1	Cambio de proveedor de envío de OTP (SMS)	Líder técnico	Aprobado sin pruebas de regresión completas
CR-046	Semana 2	Ajuste en algoritmo de score crediticio	Arquitecto (contratista)	Aprobado, documentación incompleta
CR-048	Semana 2	Activación de logs de depuración para diagnóstico de un bug	Desarrollador senior	Aprobado, sin ticket para desactivar antes de release
CR-050	Semana 3	Cambio en tiempo de expiración de sesión (de 5 a 15 min)	Product Owner	Aprobado sin validar impacto en seguridad
CR-052	Semana 3	Hotfix urgente para duplicidad de notificaciones push	Líder técnico	En pruebas, no cerrado

d) Resultados de pruebas preliminares (resumen QA):

- Pruebas funcionales: 87% de casos de prueba ejecutados, 92% de éxito.
- Pruebas de seguridad (básicas, tipo checklist OWASP Mobile Top 10): 4 de 10 categorías con hallazgos críticos o altos (almacenamiento inseguro, autenticación rota, exposición de credenciales, logging inseguro).
- Pruebas de carga: fallo en cumplir el SLA de tiempo de respuesta con más de 1,200 usuarios concurrentes.
- Pruebas de usabilidad con usuarios reales: 65% completó el flujo de transferencia sin ayuda; 35% reportó confusión en el flujo de recuperación de contraseña.
- Cobertura de pruebas automatizadas (unitarias): 54%.

3. Identificación y justificación de hallazgos

N.º	Hallazgo	Severidad	Evidencia relacionada	Impacto / Justificación	Recomendación
1	Bajo nivel de seguridad de las contraseñas de acceso de los usuarios	alta	INC-101/ RNF-004	El algoritmo MD5 es, a día de hoy, un método de cifrado prácticamente obsoleto para el almacenamiento de contraseñas, más aún si no se utiliza una cadena de carácter aleatoria (salt) antes de generar el hash. Esto implica que contraseñas iguales o similares generarán el mismo hash, lo cual permite a los atacantes emplear tablas precalculadas (<i>rainbow tables</i>) y ataques de fuerza bruta para descifrarlas. Este hallazgo compromete directamente la confidencialidad de las credenciales y la integridad de las cuentas de los asociados, además de representar un incumplimiento normativo frente a los estándares de protección de datos exigidos a las entidades financieras, con el consecuente riesgo reputacional y regulatorio para la cooperativa.	Usar bcrypt, scrypt o Argon2 con salt, en lugar de MD5
2	Tiempo de repuestas de las transacciones muy demoradas	alta	INC-112	Las transacciones de los módulos afectan la fluidez de la aplicación evidenciando que con 1,500 usuarios concurrentes (la mitad de la capacidad mínima requerida de 3,000) el tiempo de respuesta ya asciende a 9 segundos, superando el límite de 5 segundos establecido, esta tendencia permite proyectar una degradación aún mayor al alcanzar la carga máxima esperada, afectando la fluidez de la aplicación y la experiencia de uso de los asociados.	realizar una refactorización de las consultas y procedimientos almacenados involucrados en los módulos transaccionales, junto con una revisión de la estructura de tablas e índices de la base de datos, con el fin de optimizar los tiempos de lectura y escritura. Complementariamente evaluar el uso de caché

N.º	Hallazgo	Severidad	Evidencia relacionada	Impacto / Justificación	Recomendación
					para consultas frecuentes de solo lectura
3	Falla en el bloqueo de usuario al iniciar sesión con superación de intentos errados	alta	INC-108 RF-018	La ausencia de bloqueo de cuenta tras múltiples intentos fallidos de inicio de sesión constituye una falla de seguridad crítica, evidenciada durante las pruebas al registrarse 10 intentos fallidos consecutivos sin que el sistema activara el bloqueo, incumpliendo el requisito RF-018, que establece el bloqueo tras el quinto intento fallido. Esta vulnerabilidad permitiría a un atacante ejecutar ataques de fuerza bruta o de diccionario para descifrar contraseñas de los asociados, comprometiendo la confidencialidad de las credenciales y la integridad de las cuentas, con el riesgo de accesos no autorizados y ejecución de transferencias fraudulentas. Adicionalmente, representa un incumplimiento de los controles mínimos de seguridad exigidos a las entidades financieras por el ente regulador	Implementación del control de bloqueo (corrección directa del RF-018). Incorporar un mecanismo de CAPTCHA Definir un tiempo de bloqueo temporal
4	hardcoding de credenciales de integración con la pasarela de pago ACH	alta	INC-119	La codificación fija de credenciales (<i>hardcoding</i>) de claves, secretos o usuarios escritos directamente en el código fuente constituye una falla de seguridad crítica, confirmada al verificar que dichas credenciales de integración con la pasarela de pagos ACH son visibles al descompilar el archivo APK de la aplicación. Esta condición incumple de manera directa la exigencia contractual del proveedor de credenciales mediante variables de entorno cifradas. El hallazgo expone a la organización a un posible robo de datos financieros y a la suplantación de la aplicación ante el proveedor de pagos, comprometiendo la confidencialidad e integridad de las transacciones interbancarias. Adicionalmente, representa un incumplimiento de los estándares de seguridad exigidos para el manejo de medios de pago, lo que podría derivar en sanciones regulatorias y en la pérdida de confianza de los asociados y del proveedor externo.	Eliminar de forma inmediata las credenciales embebidas en el código fuente y migrarlas a un gestor de secretos con variables de entorno cifradas, conforme a la exigencia contractual del proveedor ACH. Además, es recomendable revocar y volver a generar las credenciales actuales por considerarse expuestas, y no menos importante establecer una política de cambio o rotación de estas credenciales.
5	Fallas en la doble autenticación	alta	INC-104 RF-012 CR-045	Debido al cambio de proveedor del sistema de autenticación de doble facto (CR-045) aprobado sin la ejecución de pruebas de regresión completas, lo que permitió que un error crítico pasara a producción sin ser detectado: el token OTP viaja en texto plano dentro de un log de depuración que	Remover de inmediato el log de depuración que exponen el token OTP, se recomienda exigir pruebas de regresión completas y una revisión de seguridad obligatoria para cambios

N.º	Hallazgo	Severidad	Evidencia relacionada	Impacto / Justificación	Recomendación
				quedó activo en el build de release (CR-048), incumpliendo el RF-012. Esta falla fue confirmada durante las pruebas, donde un analista de QA logró interceptar el token mediante un proxy, lo que demuestra que el segundo factor de autenticación puede ser completamente anulado, dado que un atacante con acceso a dichos logs podría completar el inicio de sesión sin necesidad del dispositivo del usuario.	relacionados con la autenticación (como el ocurrido en CR-045), y reforzar el mecanismo de doble factor con cifrado extremo a extremo y una expiración corta del código OTP

4. Actividades de verificación y validación

4.1 Actividades de verificación

Revisión técnica formal:

Es una técnica de verificación estructurada en la cual un equipo conformado por el líder técnico, desarrollador y el autor del artefacto revisan de manera formal el diseño o código fuente, contrastándolo contra los criterios y requisitos definidos para el proyecto. Como resultado, se genera un acta con los hallazgos identificados y los compromisos de corrección (Sommerville, 2021).

En el caso evaluado, se recomienda aplicar esta técnica sobre el código y los procesos que implementan el registro en bitácora de transacciones mayores a \$500.000 (RF-025) y el bloqueo de usuarios tras múltiples intentos fallidos de inicio de sesión (RF-018), dado que ambos requisitos no se están cumpliendo actualmente. La revisión debe abarcar los métodos, funciones, procedimientos almacenados y consultas involucrados en ambos flujos, con el fin de identificar por qué no se está dando cumplimiento a estos requerimientos pactados como obligatorios, y definir las correcciones necesarias antes de la liberación del sistema.

Revisión de logs/configuración:

Esta técnica de verificación consiste en examinar los archivos de configuración, niveles de log y variables de entorno del sistema, con el fin de identificar configuraciones inseguras o datos sensibles expuestos antes del paso a producción. Puede realizarse de forma manual o apoyada en herramientas de escaneo de secretos (secret scanning), que detectan automáticamente credenciales o información confidencial dentro del código y los archivos de configuración.

Esta actividad resulta fundamental en el caso evaluado, ya que se identificaron dos configuraciones inseguras relevantes: por un lado, un log de depuración activo que expone el token OTP en texto plano, generando la vulnerabilidad descrita en el hallazgo 5; por otro lado, las credenciales de integración con la pasarela de pagos ACH se encuentran escritas directamente en el código fuente (hardcodeadas), en lugar de manejarse mediante variables de entorno cifradas, tal como se describió en el hallazgo 4. La revisión de logs y configuración permitiría detectar ambos problemas antes de que el sistema sea liberado a producción.

Auditoría de control de cambios

Esta actividad de verificación consiste en revisar que cada solicitud de cambio (Change Request, CR) cuente con aprobación formal, documentación del impacto generado y evidencia de pruebas de regresión antes de integrarse a una nueva versión del sistema. Su objetivo es garantizar la trazabilidad completa entre el cambio realizado y el requerimiento que lo originó.

Esta auditoría es especialmente necesaria en el proyecto evaluado, dado que el registro de control de cambios evidencia varias inconsistencias: el CR-045 (cambio de proveedor de OTP) fue aprobado sin pruebas de regresión completas; el CR-048 (activación de logs de depuración) se aprobó sin un ticket asociado para su desactivación antes del reléase, lo cual originó la exposición del token OTP descrita en el hallazgo 5; y el CR-050 (cambio en el tiempo de expiración de sesión) fue aprobado sin validar su impacto en la seguridad del sistema. Estas situaciones evidencian la ausencia de un proceso formal de control que garantice el cumplimiento de tareas y revisiones obligatorias antes del despliegue de cualquier requerimiento a producción

4.2 Actividades de validación

Pruebas funcionales

Se ejecutó el 87% de los casos de prueba planificados, obteniendo un 92% de éxito, lo cual refleja un nivel alto de cumplimiento funcional. Sin embargo, este resultado valida principalmente que el sistema "funciona", mas no garantiza que lo construido responda completamente a las necesidades reales del cliente, por lo que se recomienda complementar con pruebas de aceptación del usuario antes de la liberación.

Pruebas de seguridad

Se ejecutaron pruebas de seguridad básicas basadas en el checklist OWASP Mobile Top 10, encontrando hallazgos críticos o altos en 4 de las 10 categorías evaluadas: almacenamiento inseguro, autenticación rota, exposición de credenciales y logging inseguro. Estas categorías corresponden directamente a los hallazgos identificados en la sección 3 del presente reporte (almacenamiento de contraseñas con MD5 sin salt, ausencia de bloqueo de cuenta, credenciales hardcodeadas y exposición del token OTP en logs), lo cual confirma que el sistema, en su estado actual, no cumple con las exigencias mínimas de seguridad requeridas para una aplicación financiera, ni con los requisitos contractuales exigidos por terceros involucrados, como el ente regulador y el proveedor externo de la pasarela de pagos.

Pruebas de carga

El caso evaluado, los resultados de pruebas preliminares reportaron fallos en el cumplimiento del SLA de tiempo de respuesta a partir de 1,200 usuarios concurrentes, cifra muy por debajo de los 3,000 usuarios concurrentes que la aplicación debe soportar en horas pico según las restricciones técnicas del sistema. Esto se confirma con el hallazgo 2 (INC-112), donde se evidenció que, con 1,500 usuarios concurrentes, el tiempo de respuesta de las transferencias ascendió a 9 segundos, superando el límite máximo de 5 segundos establecido. Estos resultados evidencian que el

sistema no está preparado para operar de forma estable bajo la carga máxima esperada, lo cual resulta especialmente crítico considerando que la salida a producción coincide con una campaña comercial de vinculación de nuevos asociados.

Pruebas de usabilidad

Estas pruebas evalúan la facilidad con la que usuarios reales logran completar tareas dentro del sistema, sin asistencia externa. En el caso evaluado, el 65% de los usuarios completó el flujo de transferencia sin ayuda, mientras que el 35% reportó confusión en el flujo de recuperación de contraseña (RF-012). Este resultado no constituye un hallazgo de seguridad, pero sí una debilidad relevante de calidad, considerando que muchos de los asociados de la cooperativa presentan un bajo nivel de alfabetización digital, según se describió en el perfil de actores del caso. De no atenderse, esta dificultad podría traducirse en abandono del proceso, incremento de solicitudes al soporte técnico y una experiencia negativa justo en el momento de lanzamiento, que coincide con una campaña comercial de vinculación de nuevos asociados. Se recomienda simplificar el flujo de recuperación de contraseña y complementarlo con manuales de usuario o guías interactivas dentro de la aplicación.

4.3 Matriz de verificación y validación

Requisito / Funcionalidad	Tipo (V/V)	Técnica / Actividad	Responsable	Resultado / Estado
RF-018 – bloqueo de usuario al intentar el login muchas veces	Verificación	Revisión técnica formal	Líder técnico y desarrollador	No conforme – ver hallazgo 3
RNF-004 – Almacenamiento de contraseña con algoritmos estándares de hasheo	Validación	Pruebas de seguridad	Equipo de QA	No conforme – ver hallazgo 1
RF-012 – Cambio/recuperación de contraseña mediante código de verificación	Validación	Pruebas de usabilidad	Equipo de QA	No conforme – 35% de usuarios reportó confusión en el flujo (ver sección 4.2)
RT - manejo de credenciales de integración con la pasarela ACH mediante variables de entorno cifradas	Verificación	Revisión de logs/configuración	Líder técnico y desarrollador	No conforme – ver hallazgo 4
RF-025 El sistema debe registrar en bitácora toda transacción mayor a \$500,000	Verificación	Revisión técnica formal	Líder técnico y desarrollador	No conforme – INC-121

5. Lista de verificación de revisión técnica

N.º	Ítem de verificación	Cumple (Sí/No/N.A.)	Observaciones
1	El código fuente cumple con los estándares de codificación definidos por el equipo.	No	Se identificaron incumplimientos puntuales, como el uso de un algoritmo de hash obsoleto (MD5 sin salt) para contraseñas y credenciales hardcodeadas en el código fuente (ver hallazgos 1 y 4)
2	Existe trazabilidad entre los requisitos y los casos de prueba.	Si	Existe una matriz de resultados de pruebas con el 87% de casos ejecutados y 92% de éxito, aunque la cobertura de pruebas automatizadas (unitarias) es baja, del 54%, lo que indica trazabilidad parcial entre requisitos y pruebas.
3	Todos los cambios fueron documentados y aprobados antes de su despliegue a producción.	No	Algunos cambios quedaron sin su documentación correspondiente
4	Los mecanismos de autenticación y autorización protegen adecuadamente los recursos críticos.	No	Existen muchos fallos de seguridad encontrados dentro del análisis
5	La información sensible (financieros) se almacena y transmite cifrada	No	El almacenamiento de contraseñas mediante MD5 sin salt evidencia que no se está aplicando un cifrado robusto sobre información sensible, tal como lo exige la restricción técnica del sistema (ver hallazgo 1).
6	Existen registros de auditoría (logs) para accesos y modificaciones a información crítica	Si	Si se registran, pero presentan un mínimo fallo en un porcentaje bajo de no registro en algunos casos.
7	Se ejecutaron pruebas de seguridad antes de la liberación	Si	No satisfactorias
8	Se ejecutaron pruebas de carga/rendimiento sobre los módulos críticos.	Si	No se cumplió con la estabilidad de concurrencia para el número de usuarios en simultaneo solicitado en las restricciones
9	Se cumple con las políticas de uso de la pasarela de pago ACH	No	Se encontraron fallas de seguridad en el hardcodeo de las credenciales
10	Se cumple con políticas de control y normas de protección de datos personales y estándares de seguridad	No	Se evidencian múltiples debilidades de seguridad y cumplimiento normativo, como el almacenamiento inadecuado de contraseñas, la exposición de credenciales y del token OTP, y la ausencia de bloqueo de cuentas (ver hallazgos 1, 3, 4 y 5), lo cual compromete el cumplimiento de la normativa de protección de datos y los estándares exigidos a entidades financieras

6. Plan breve de auditoría

6.1 Objetivo

Determinar el nivel de cumplimiento del sistema CoopFinanza App frente a los requisitos de seguridad, funcionalidad y normativos establecidos para su operación, con el fin de evaluar si el software se encuentra en condiciones adecuadas para su liberación a producción, considerando su próximo lanzamiento y su aplicación en el sector financiero.

6.2 Alcance

Específicamente, se revisarán:

- La autenticación de usuarios, incluyendo el cumplimiento del segundo factor mediante código de verificación enviado por SMS.
- Las transferencias interbancarias en tiempo real.
- El pago de servicios públicos.
- La solicitud de créditos exprés.
- La gestión de credenciales de los usuarios.
- Las notificaciones push de movimientos.
- El cumplimiento de las políticas de seguridad exigidas por los terceros involucrados (ente regulador y proveedor de la pasarela ACH).

Quedan fuera del alcance de esta auditoría la infraestructura interna del proveedor externo de la pasarela de pagos ACH y las funcionalidades no críticas del sistema, como la gestión de certificados de aportes. El período evaluado corresponde a las últimas cuatro semanas de pruebas y control de cambios, conforme a la evidencia disponibles.

6.3 Criterios de auditoría

Los criterios que se sustentan en la presente auditoria son:

- Revisión de requisitos funcionales para el sistema, se busca:

verificar si el proceso de restablecimiento de las contraseñas de los usuarios cumple el requisito (RF-012) y permite la autenticación por código de verificación vía correo o SMS.

verificar que los usuarios sean bloqueados después de 5 intentos fallidos en su inicio de sesión

verificar el registro de movimientos de transacciones mayores a \$500.000 en bitácora para temas de auditoria

- Restricciones técnicas y regulatorias

verificar el cifrado de datos

verificar la concurrencia y desempeño de los módulos con usuarios en simultaneo

verificar la trazabilidad de la información y que se almacene de forma correcta en tablas de auditorias

verificar la protección de datos personales

- El estándar internacional de calidad como la ISO/IEC 25010.

verificar la Seguridad

verificar la Fiabilidad

verificar la Eficiencia del desempeño

verificar la Usabilidad

- Exigencias contractuales de terceros como los del proveedor ACH que exige variables de entorno cifradas, no hardcodeadas.

6.4 Evidencias a recolectar

Entre las evidencias de la auditoria se recopilarán:

Fragmentos de requisitos que especifican los requerimientos tanto funcionales como no funcionales que debe cumplir el sistema.

Los extractos de bitácora de incidencias de las últimas 3 semanas de pruebas que sustentan las incidencias encontradas en el software

La lista de control de cambios que demuestra si se maneja de forma correcta el proceso de aprobaciones, asignación de responsables, documentación, estado y trazabilidad de los cambios en el flujo de correcciones en el manejo de versiones

Los Resultados de pruebas aplicadas por el equipo de QA, pruebas de carga, pruebas de seguridad, pruebas de usabilidad que permiten identificar incumplimientos frente a los criterios de auditoría establecidos

7. Estándar o referencia aplicada al caso

El estándar ISO/IEC 25010 se ajusta perfectamente al caso estudiado. Es un estándar internacional utilizado para la evaluación de la calidad de productos y sistemas de software, el cual permite tener una guía de referencia para los equipos de desarrollo y control de calidad (QA) que les permite crear software seguros, mantenibles y eficientes

El estándar evalúa dos modelos principales los cuales son:

- Modelo de Calidad del Producto
- Modelo de Calidad en Uso

La norma ISO/IEC 25010 se basa en un modelo de calidad que sirve como marco de referencia para orientar el diseño, desarrollo y evaluación de productos de software. A partir de las características de calidad definidas por este estándar, es posible establecer criterios y diseñar casos de prueba específicos para verificar el cumplimiento de los requisitos del sistema. Adicionalmente, el proceso de evaluación puede apoyarse en herramientas especializadas que permiten medir diferentes atributos de calidad, automatizar pruebas y realizar análisis estático del código, facilitando la identificación de posibles incumplimientos frente a las características establecidas por la norma.

Conociendo este concepto este estándar es precisamente lo que requiere evaluar el presente trabajo donde la intención es determinar si el sistema del caso hipotético cumple con el listado de verificación que aplica este marco como lo son:

- **La Funcionalidad**, que evaluara el cumplimiento de los requisitos y necesidades del usuario. Esta característica se aplica verificando el correcto funcionamiento de procesos como la recuperación de contraseña mediante código de verificación (RF-012), el bloqueo de cuentas después de cinco intentos fallidos (RF-018) y el registro en bitácora de las transacciones superiores a \$500.000 (RF-025), determinando si el sistema responde conforme a las necesidades establecidas
- **La Fiabilidad**, que permitirá evaluar la capacidad del sistema para mantener un funcionamiento estable y recuperarse ante posibles fallos. En el caso analizado, esta característica puede evaluarse mediante la revisión de la bitácora de incidencias y los resultados de las pruebas realizadas, con el fin de identificar la frecuencia, severidad y comportamiento de los errores detectados durante la fase de pruebas.
- **La Usabilidad**, que evaluara si el sistema es fácil de usar, intuitivo y responde correctamente. Para el caso, esta característica se aplica mediante los resultados de las pruebas de usabilidad realizadas por el equipo de QA, las cuales evidenciaron que el 35 % de los usuarios presentó dificultades en el proceso de recuperación de contraseña, identificando oportunidades de mejora en la experiencia de uso de la aplicación.
- **La Eficiencia de Rendimiento**, que medirá los tiempos de respuesta y el consumo de recursos. Para el caso hipotético analizado, esta característica se aplica mediante los

resultados de las pruebas de carga, donde se evidenció que las transferencias alcanzaron tiempos de respuesta de 9 segundos con 1.500 usuarios concurrentes, incumpliendo el límite de 5 segundos establecido y demostrando la necesidad de optimizar el rendimiento del sistema antes de su liberación.

- **La Seguridad**, la cual permitirá evaluar si el sistema protege adecuadamente la información de los asociados. En el caso analizado, esta característica se relaciona con los hallazgos encontrados durante la auditoría, como el almacenamiento de contraseñas mediante MD5 sin *salt*, la exposición del token OTP en los registros de depuración y el uso de credenciales hardcodedas para la integración con la pasarela ACH, situaciones que comprometen la confidencialidad e integridad de la información.

8. Definición de métricas de calidad

N.º	Métrica	Fórmula / Forma de medición	Unidad	Criterio de aceptación
1	Tiempo promedio de respuesta de las transferencias	Medir el tiempo que tarda cada transferencia durante una prueba de carga y calcular el promedio de todos los tiempos registrados	Segundos (s)	El tiempo promedio debe ser menor o igual a 5 segundos.
2	Porcentaje de cuentas bloqueadas correctamente	$(\text{Número de cuentas bloqueadas después de 5 intentos fallidos} / \text{Total de cuentas evaluadas}) \times 100$	%	El 100 % de las cuentas debe bloquearse después del quinto intento fallido.
3	Porcentaje de transacciones registradas en la bitácora de auditoría	$(\text{Número de transacciones registradas correctamente} / \text{Total de transacciones que debían registrarse}) \times 100$	%	El 100 % de las transacciones superiores a \$500.000 deben quedar registradas en la bitácora.
4	Porcentaje de vulnerabilidades críticas corregidas	$(\text{Número de vulnerabilidades críticas corregidas} / \text{Total de vulnerabilidades críticas identificadas}) \times 100$	%	El 100 % de las vulnerabilidades críticas debe estar corregido antes de la liberación a producción.
5	Porcentaje de usuarios que completan el proceso de recuperación de contraseña sin ayuda	$(\text{Número de usuarios que completan el proceso sin asistencia} / \text{Total de usuarios participantes}) \times 100$	%	Al menos el 90 % de los usuarios debe completar el proceso sin ayuda.

9. Conclusiones y recomendaciones priorizadas

Como resultado del análisis realizado mediante métricas, actividades de verificación, validación y auditoría, apoyadas en el estándar ISO/IEC 25010, se concluye que el sistema **CoopFinanza App** no se encuentra en condiciones de ser liberado a producción, debido a que presenta incumplimientos importantes en aspectos de seguridad, rendimiento y funcionalidad.

Por lo tanto, se recomienda priorizar la corrección de los hallazgos críticos identificados, realizar nuevamente las pruebas correspondientes y verificar el cumplimiento de los requisitos antes de autorizar su liberación. De no atenderse estas deficiencias, la cooperativa podría enfrentar riesgos

de seguridad, incumplimientos normativos y una afectación a su reputación durante el lanzamiento de la aplicación.

Referencias

International Organization for Standardization. (2011). *ISO/IEC 25010:2011 — Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — System and software quality models*. ISO.

Pressman, R. S., & Maxim, B. R. (2019). *Ingeniería del software: Un enfoque práctico* (9.^a ed.). McGraw-Hill Education.

Sommerville, I. (2021). *Software Engineering* (11th ed.). Pearson.